

Manual 51 — Agentic AI Governance, Security & Human Accountability

Controlled publication source

Currentness baseline: 1 September 2026

Normative-status rule: IMDA, NIST and OWASP materials are used according to their actual status; this manual does not convert voluntary guidance, drafts, community guidance or concept papers into law or certification requirements.

Purpose

This manual provides a practical governance and security operating model for AI agents that can plan, invoke tools, access enterprise data, maintain memory, delegate to other agents and take consequential actions. The governing principle is simple: agentic AI must be governed by the consequences of its actions, not only by the quality of generated text.

Current source baseline

- IMDA Model AI Governance Framework for Agentic AI v1.0, published 22 January 2026, is treated as government governance guidance focused on facilitating human accountability when AI agents are used.
- NIST AI RMF 1.0 and NIST AI 600-1 remain voluntary risk-management guidance.
- NIST's February 2026 software and AI-agent identity/authorization concept paper remains a concept-stage publication, not a final mandatory standard. Its identity, authorization, auditing and non-repudiation topics are used as emerging technical guidance.
- NIST's August 2026 public discussion of agentic identity reinforces the need for attributable identities, least privilege and strong authorization foundations.
- OWASP Top 10 for Agentic Applications 2026 and the State of Agentic AI Security and Governance 2.01 are treated as community security guidance, not legal or certification requirements.

Agentic control architecture

AG-01 Agent identity

Every production agent or agent service that can reach enterprise resources must have an attributable identity tied to an accountable owner and approved purpose. Evidence includes inventory record, workload identity, owner, environment and credential lifecycle.

AG-02 Authentication and credential control

Agents authenticate with controlled credentials. Shared human accounts, embedded long-lived secrets and unmanaged tokens are prohibited unless specifically risk-accepted and compensating controls are documented. Evidence includes token lifetime, rotation and secret-management records.

AG-03 Authorization and least privilege

Grant only the tools, data and actions needed for the approved use case. Authorization must be independently enforced by technical controls rather than prompt instructions alone. Review privilege as capabilities change.

AG-04 Capability and autonomy bounding

Document allowed goals, actions, tools, data domains, transaction limits, external communications, code execution and prohibited activities. Autonomy is classified by consequence and reversibility.

AG-05 Significant human checkpoints

Define where accountable human authorization is required before legal, financial, safety, employment, access-control, external-communication or irreversible actions. Approval must be meaningful: the approver receives enough context, has authority to reject and the system enforces rejection before execution.

AG-06 Tool, MCP and API trust boundaries

Treat tools, MCP servers, APIs, plugins and connectors as security boundaries. Maintain tool inventory, trust classification, schema validation, scopes, provider assessment, allowlists and explicit action limits.

AG-07 Data and memory boundaries

Control what agents may read, retain, retrieve, write or disclose across session memory, long-term memory, RAG stores and third-party services. Record lineage, retention and data-access restrictions.

AG-08 Instruction and prompt-boundary integrity

Protect system instructions, trusted context and tool-selection logic from untrusted content and indirect prompt injection. Separate trusted instructions from retrieved or user-supplied content and validate tool arguments.

AG-09 Action provenance

Material agent actions must be reconstructable: requestor/context, agent identity/version, policy decision, tool call, approval/denial, execution result, downstream effect and monitoring outcome.

AG-10 Multi-agent delegation control

Define which agents may delegate to others, what authority transfers and how memory, credentials and tools remain bounded. Prevent privilege amplification through delegation chains.

AG-11 Third-party agent/provider governance

Assess external models, agents, plugins and tools for data handling, permissions, change notification, incidents, continuity, concentration and exit risk.

AG-12 Monitoring and anomaly detection

Monitor unusual tool use, privilege changes, high action velocity, repeated policy denials, unexpected delegation, sensitive-data access, material overrides and abnormal side effects.

AG-13 Containment and kill capability

Provide tested mechanisms to stop the agent, revoke credentials, disable tools, isolate environments and prevent further harmful actions. Test containment before production and periodically thereafter.

AG-14 Incident response

Integrate agent incidents into enterprise incident response. Preserve prompts/instructions, identities, traces, tool calls, approvals, model/provider versions, policy versions and affected systems needed for reconstruction.

AG-15 Change and revalidation

Material changes in model, system instructions, tools, permissions, autonomy, provider, data sources, RAG, memory, geography or purpose trigger risk reassessment and proportionate revalidation.

AG-16 Testing and adversarial evaluation

Test normal and adversarial behavior including unauthorized tool use, prompt injection, privilege escalation, cross-agent manipulation, data leakage, unsafe autonomy, tool spoofing, poisoned memory and containment response.

AG-17 Human competence and automation-bias control

People supervising agents must understand limits, evidence and escalation paths and must retain independent judgment where human accountability is required. Measure overrides, disagreements and sampled decision quality.

AG-18 End-user transparency and responsibility

Where relevant, users should know they are interacting with an agent, what it can do, material limitations, what actions it may take and how to challenge or escalate problems.

AG-19 Governance and risk acceptance

Deploy, restrict, suspend or retire agentic capability based on documented risk, test evidence, residual risk and accountable approval. Exceptions are time-bounded and monitored.

AG-20 Auditability and continuous assurance

Maintain sufficient evidence to periodically test whether agent governance and security controls remain effective as models, tools, permissions and dependencies evolve.

Autonomy classes

- ****Class A — observe only:**** autonomous observation and recommendation, no external side effect.
- ****Class B — reversible bounded action:**** autonomous within explicit technical limits and continuous monitoring.
- ****Class C — material action:**** accountable human approval before execution unless a documented emergency policy authorizes bounded automation.
- ****Class D — irreversible/high-impact action:**** dual control or designated accountable approval with enhanced evidence and rollback/containment planning where possible.

Evidence model

Minimum reusable evidence includes: agent inventory; action-boundary specification; identity and authorization design; tool/data allowlist; human-accountability matrix; action provenance; safety/security evaluation; change/revalidation record; monitoring record; kill/containment test; incident record; third-party assessment; exception/risk acceptance; and independent assurance results.

Every consequential action should be reconstructable through this chain:

requestor/context → agent identity/version → authorization/policy evaluation → requested tool/action → approval or denial → execution result → downstream side effect → monitoring or incident outcome

Practical scenarios

Procurement agent

An agent may read approved vendor data and draft purchase requests, but execution privileges are separately scoped. Value thresholds and non-approved vendors require human approval or technical denial. Evidence includes scopes, approvals, denied calls, transaction logs and rollback testing.

Multi-agent publishing chain

Research, summarization, drafting and publishing privileges are separated. Every delegation hop is attributable. External publication is isolated behind a controlled boundary, with human approval when materiality requires it.

Third-party tool behavior change

Provider version changes trigger schema-diff review, supplier-risk reassessment, regression tests and revalidation before expanded output or permissions are accepted.

Prohibited data export

A request to send restricted customer information to an unapproved destination must be denied before tool execution. Preserve user/agent attribution, policy rule, classification context, destination rule and investigation disposition.

Autonomous security remediation

Observe-only actions may be autonomous; reversible containment may be bounded; high-impact credential revocation or production isolation requires stronger approval according to business impact and emergency policy.

Privilege drift

Cumulative permission changes are reviewed as a consolidated risk delta. Toxic combinations, newly reachable systems and expanded delegation authority trigger revalidation.

Human-accountability operating rule

Human oversight is not satisfied merely by placing a person in the workflow. The checkpoint is effective only when the person is identifiable, competent, informed, authorized to reject,

given sufficient time/context, and technically able to stop the action before the consequential side effect occurs.

Cross-framework use

IMDA provides a governance orientation for accountability and agentic use. NIST provides risk-management and emerging identity/authorization considerations. OWASP provides practical security threat and mitigation guidance. These sources may support the same enterprise control but must retain their distinct status, scope and assurance implications. No crosswalk may claim that adopting one source proves compliance with another.

Deployment gate

Before production, confirm: approved purpose and owner; inventory record; autonomy class; agent identity; least privilege; tool/data boundaries; human checkpoints; provenance; adversarial tests; containment test; third-party review; monitoring; incident integration; revalidation triggers; residual-risk decision; and evidence retention.

Final release criterion

The manual is release-ready when AG-01 through AG-20 are represented in the controlled trilingual sources, the six DOCX/PDF artifacts are generated from those sources, visible-text and render checks pass, the exact artifact hashes and byte counts are frozen, publication registries are reconciled, workflow-security remains clean, predecessor Manual 50 is published, and no unresolved substantive or technical defect remains.